

24th International Conference on Knowledge-Based and Intelligent Information & Engineering Systems

**Data Security Platform Model in Networked Medical IT Systems
based on Statistical Classifiers and ANN**Miroslaw Hajder^a, Janusz Kolbusz^{a,*}, Piotr Hajder^b, Mariusz Nycz^c, Mateusz Liput^a^aUniversity of Information and Management, 35-225 Rzeszow, Poland^bAGH University of Science and Technology, 30-059 Krakow, Poland^cRzeszow University of Technology, 35-959 Rzeszow, Poland

Abstract

The paper presents the results of research on improving the security of medical information systems. It begins with a presentation of the specific features of such systems in terms of functionality and potential risks. It was assumed that the features distinguishing medical systems from other information systems are: patient orientation, confidentiality of the information processed, state interference in the functioning of medical entities and the need to ensure maximum availability of system resources. The last requirement results from treating medical IT systems as elements of critical infrastructure, for which business continuity is one of the key features. The work focused on limiting the systems' sensitivity to cyber-attacks limiting their availability. A software and hardware platform dedicated for attack detection is presented. The system uses parallel processing and artificial intelligence and is distinguished by several alternative detection methods, the use of expert system to make decisions about protection measures and the ability to independently identify unknown attacks. Paper ends with an evaluation of prototype testing results and directing further work in this area. The work is addressed to people involved in the operation of medical information systems.

© 2020 The Authors. Published by Elsevier B.V.

This is an open access article under the CC BY-NC-ND license (<https://creativecommons.org/licenses/by-nc-nd/4.0>)

Peer-review under responsibility of the scientific committee of the KES International.

Keywords: health informatics; health information systems; medical information systems; artificial intelligence; computer systems security

1. Introduction

Medical information systems (MIS) should be treated as an essential element of any health care system. The first works concerned MIS were published at the end of the 1950s. As part of analysis of medical decision-making methods in conditions of risk and uncertainty, computer-assisted medical decision-making was proposed for the first time. The first practical implementations in this area occurred in 1960s. They included the construction of databases collecting and sharing information about patients of the medical entities using *mainframe* computers. In the following decades,

* Corresponding author

E-mail address: jkolbusz@wsiz.rzeszow.pl

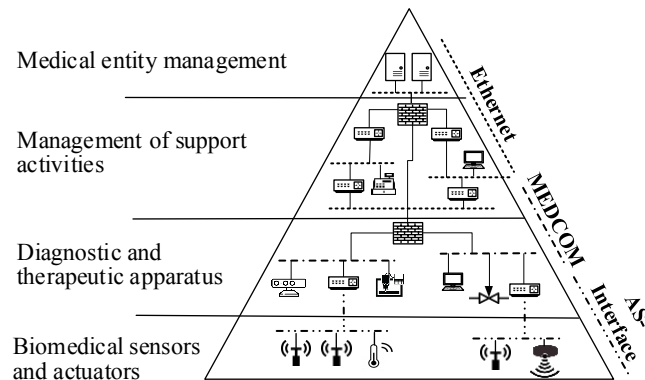


Fig. 1. Hierarchical model of medical information systems

research in the area of MIS focused on creating medical entity management systems, which the main purpose was to improve their financial efficiency. Then, the use of IT tools for diagnostic and therapeutic procedures was secondary task. Nowadays, the main role in preparation standard of functioning the medical information systems plays the International Medical Informatics Association (IMIA).

Permanent availability of MIS resources, apart from their privacy and security, is one of the most important properties of these systems. What can threaten medical information systems? Are these systems an interesting target for attacks? In many countries, MIS are treated as element of the critical infrastructure of the state, therefore they will be an attractive target for politically motivated cyber terrorist attacks. MIS vulnerability to attacks results, among others from heterogeneity of their hierarchical architecture shown in Fig. 1. The presented model of the architecture consists of four layers, in which the most important includes the components intended for basic management of medical entities (accounting, human resources, material economy, settlement of medical services and others). In second layer of model support medical systems are located (drug economy, food, laboratory, diagnostic imaging, archiving documentation etc.). The third layer consist of autonomic tools of diagnosis and therapeutic. The devices in this level have their own software and hardware ensuring their independent operation. The results of biomedical measurements of the patient's body undergoing therapeutic or rehabilitation procedures obtained with their help are archived on an ongoing basis. The fourth layer integrates stationary and mobile measuring sensors with MIS, which are a source of patient information for the other layers.

As shown in Fig. 1, in two upper layers of the model, the communication is homogenic and relies on Ethernet standard. The other levels are using various forms of wired communication or have significant wireless security problems. A breakthrough in the perception of threats caused by malware was the disclosure of a new class of Internet worms attacking industrial installations (including medical ones) and residing in PLC controllers [1, 2]. Such viruses as Stuxnet, Flame, Duqu, Gauss et al. were in fact aimed at destroying the network infrastructure, or more broadly industrial (including medical) infrastructure located on the lower two levels of the model in Fig. 1.

Paper describes the authors experiences in the range of construction and deployment of security systems to MIS. It consists of 5 paragraphs and references. The *Introduction* justifies the relevance of research, presents the main threats to medical information systems and methods to eliminate them. In second paragraph – *The MIS security* – with the support of context diagrams IEDF0 the security components and their mutually relationship are presents. In third paragraph functional components of security system and the fundamental algorithm of functioning system was presented. The fourth paragraph discusses the hardware architecture of the system, and the fifth prototype testing and summary. In this work, we present a system preventing DDoS attacks, one of the most dangerous for MIS. The proposed protection can exist at any of the levels in the model Fig. 1.

2. The MIS security

Medical information systems are examples of specific IT systems processing input data to some output results, with help of a set of procedures and models. Their security depends equally on the organization of the system and the

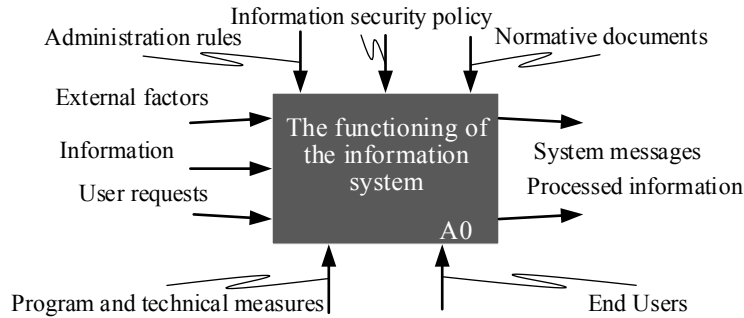


Fig. 2. Contextual diagram of the medical information system

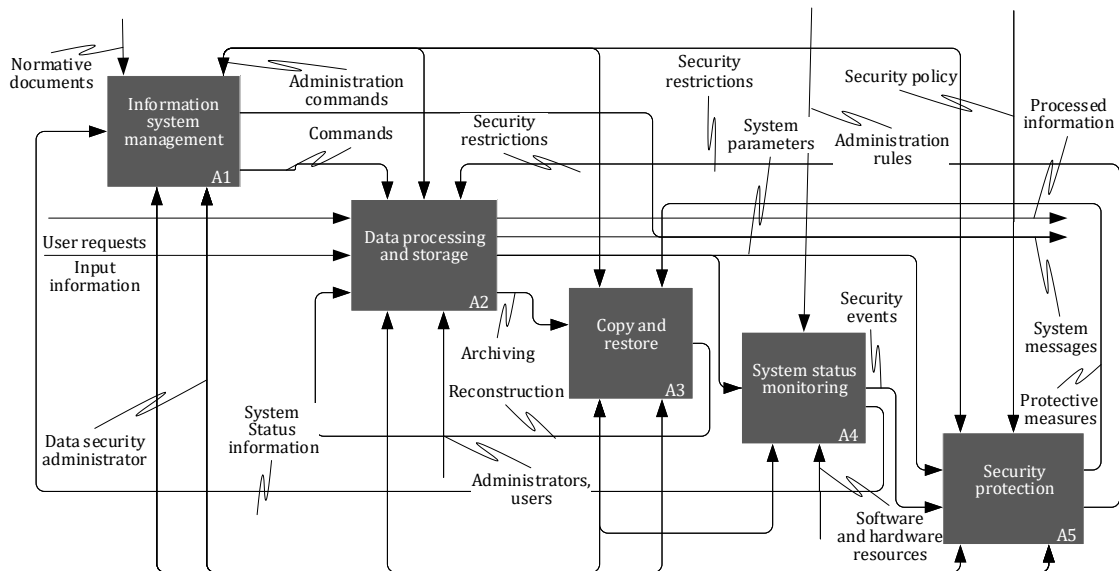


Fig. 3. A detailed context diagram of the medical information system, including protective elements

conditions of the surrounding environment. To present above dependencies, which are the starting point for protective measures, the information system and their immediate environment should be mapped using the IDEF0 methodology, designed for graphical presentation and functional modeling of business processes [3, 4, 5, 6]. Using this method, we can define in detail the relationship between functional components of MIS, omitting the sequence of works performed. This description can be freely specified using components with an appropriate level of abstraction. The elements of model are in the form of black boxes, which are entered with information processed by the block in accordance with users' requests, as well as external factors that can destabilize the work of the entire MIS. They can be both catastrophic phenomena, as well as cyber-attacks of varying character and intensity. The functioning of the system is determined by its software and hardware resources and end users. In turn, security is ensured by means of general IS administration rules, normative documents such as laws, regulations, standards, and the information security policy created on their basis. The result of the system's work are processed information and warning message [6, 7, 8].

The generalized MIS model operating in a real environment, made in this standard, is shown in Fig. 2. A detailed context diagram of the medical information system, being a further development, is shown in Fig. 3.

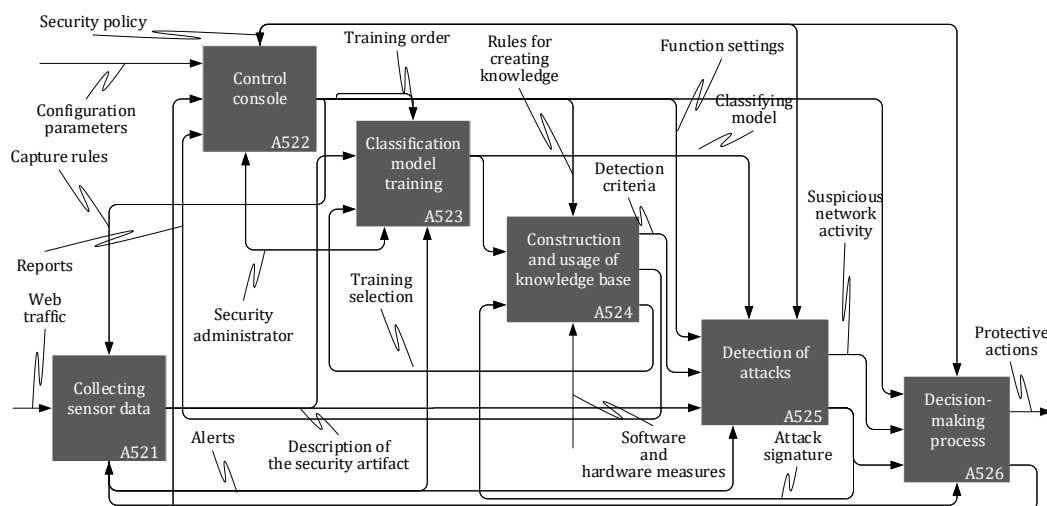


Fig. 4. Context diagram of the attack detection system

From a functional point of view, the information system presented using the model in Fig. 3 consist of five basic, mutually related subsystems:

- *Information system management*, which task is to control components of the information system;
- *Data processing and storage* responsible for the collecting, processing, storing and sharing information describing the entity and the processes occurring in it;
- *Copying and restoring* to protect the information collected from loss;
- *System status monitoring* to ensure permanent verification of the system's correctness of functioning;
- *Security protection* responsible for protecting system from attacks, in accordance with the security policy implemented.

In practice, the composition of the security subsystem can vary depending on the specific implementation, type of economic activity and organizational and legal form of the organization, as well as the relevant security requirements of normative documents created by regulators.

The purpose of the work was to design, build and test in real conditions a universal software and hardware platform for detecting MIS misbehaviors. The use of traditional solutions for this is problematic. First, in MIS, medical entity management servers as well as intelligent biomedical sensors can be targeted with an equal likelihood. Secondly, the MIS software and hardware environment is heterogeneous, which requires various protective measures. In order to make the detection procedures as independent as possible from the phenomena occurring in MIS, a separate connection network was used to integrate the detection system components, and computational operations are performed on separate servers. In addition, it was assumed that traffic anomalies in network segments will be tracked, and computational nodes load anomalies will be analyzed second. The attack detection subsystem (ADS) is isolated from external networks, and any connection to the Internet is done under strict administrator supervision.

The detection system components are presented with context diagram shown in Fig. 4 [6]. In the diagram, six functional blocks can be distinguished:

- *Collecting sensor data* consisting of a set of intelligent measuring sensors that track movement at selected points in the system. The information from their output are downloaded, collected and pre-processed to obtain information about the security status of the network segment;
- *Control console* that allows the administrator to configure ADS settings in the dialog via the operator console;

- *Classification model training*, whose task is to create a classification model during the training process and its improvement procedure, performed during the network operation;
- *Construction and usage of a knowledge base* collecting pretrained classification models, including system configuration settings;
- *Detection of attacks*, which analyzes events occurring in the protected network and, based on specific criteria, determines the degree of harmfulness registered and classifies them as an attack;
- *The decision-making process* based on the developed methodology displays alerts on the console and defines a set of protective measures used to block current attacks and prevent them in the future.

From the engineering point of view, the developed solution is distinguished by the following features: the hardware platform has a scalable organization and is managed by the Linux operating system; tooling environment is based on the MPI library; attack detection is performed using a group of alternative methods, and the decision-making process itself is based on a self-learning expert system. The constructed instrumentation is characterized by minimizing the number of erroneous detections and the ability to detect attacks that have not yet been detected in the system. The increasing communication and computational activities in the MIS resulting from the functioning of the detection system are eliminated from the analysis procedure. The proposed architecture is simple in functional and size scaling. Adding a new attack scheme does not involve any need for any interference with existing hardware and software and adding a new analyzing sensor can be done even in a working system. The described detection system ensures the improvement of operational and application mobility, and its installation is trivial.

3. Architecture of the protection subsystems

The system described has been implemented and tested for the first two layers of the model from Fig. 1. Because one of the basic security requirements is multi-level protection, in the system from Fig. 5, the information streams flowing in the system were separated using firewalls, switches of different layers and routers. The architecture is characterized by resistance to overloads and a high level of availability and longevity of supported resources. The applied solutions ensure continuous functioning of the information system that processes large volumes of data, both by internal and external users, as well as components of the biomedical diagnostic and therapeutic system. In order to ensure continuity of communication with external networks, Internet access is provided through two independent links using BGP routing protocol to maintain stability of supply.

In accordance with good MIS building practices, end users' access to system resources is accomplished by a thin client. Web servers are protected against attacks by firewalls blocking access to ports other than 80 and 443. Biomedical diagnostics information is collected and processed on application servers. Therefore, access to them is strictly limited, among others they are invisible from outside the internal network. All access to information stored on the servers is performed by a thin client and web servers. The required level of resilience is obtained by increasing its consistency. In practice, this is achieved by increasing the number of active elements of the filtration subsystem (routers, switches, and firewalls) and their appropriate combination. In the system from Fig. 5, due to duplication of components, damage to any of the subsystem elements does not result in loss of availability. A high level of availability is also ensured by redundant servers, the number of which is selected based on the number of service requests per unit of time. Redundancy of firewalls, in addition to counteracting overloads, is aimed at ensuring continuous consistence of the graph-model, i.e. maintaining the availability of resources for internal and external users. The number of firewalls used to connect the internal network to protected resources can be adjusted to the traffic, which can be divided between firewalls based on ports, addresses or load. The use of two independent connections to the Internet with the agreed way of using the BGP protocol serves similar purposes.

In the practical implementation of an information system, its architecture and organization do not always reflect the context diagram. For the diagram in Fig. 4, the practical implementation of an intrusion detection system will consist of the following components:

- *Knowledge collection subsystem* gathers knowledge about the work of protected MIS, using a set of agents based on the Arduino or Raspberry platforms. Increasing the number of agents and the types of information they analyze improves the effectiveness of attack detection. The number of agents limits the minimum acceptable

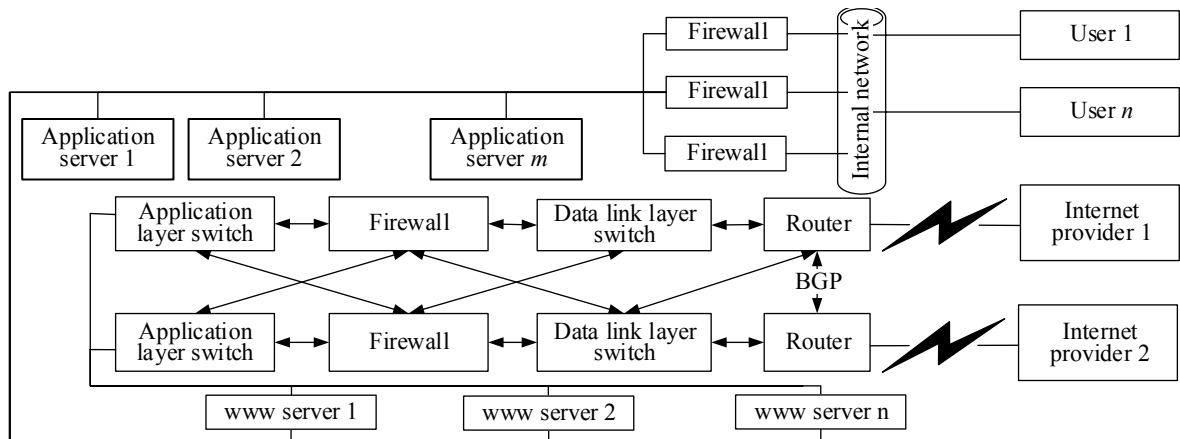


Fig. 5. Architecture of an extended firewall

level of threat detection from the bottom, while from the top – the costs and the number of processes in the system that are tracked. For medium-sized systems, this number is between a 5 and 20. Information about potential attacks goes not only to the expert system, but also to the knowledge construction subsystem and the decision-maker involved in the process of building database content;

- *The expert attack detection subsystem* based on mathematical analysis of data about events occurring in the protected system, provided by agents and knowledge about the characteristic symptoms of attacks stored in the symptom database;
- *Signaling subsystem* ensuring simple communication with the user or administrator when an attack is detected. This element is built in accordance with the principles of the theory of human-machine interaction.

The interconnection of the specified components creates a fully functional attack detection system as shown in Fig. 6. Note that the sensor subsystem can be implemented in several ways. If the detection involves a wireless network, then the first type of sensors will be based on separate modules intercepting network traffic and passing it to ADS processing modules. At the same time, the traffic generated between network clients is not translated. The second alternative solution involves embedding the sensor in the access point. In this case, scanning the network for anomalies in its functioning is less precise due to the need to share the resources of the receiving device between securing the normal operation of the network and scanning channels for network malfunctions. The third type of sensor is programmatic and implemented on the network client resources. This solution is the least effective, because scanning takes place only in the area of customer coverage. The advantage of the solution is the fact that it is cost-free, as well as detecting errors in the client's configuration and the communication channel connecting it to the main network resources.

The first approximation assumed that all ADS hardware components would be made using Raspberry PI devices. Since the designed system should work in real time, the computational performance of these devices raised justified doubts. Therefore, it was assumed that the hardware architecture must be parallel and based on several (four) processor modules forming a multi-machine system. The initial implementation of the system, however, showed that the achieved performance is insufficient in the training mode. That is why the discussed system used classic computers for threat analysis. This solution allowed to broaden the spectrum of detection methods, in particular for solutions using artificial neural networks, the expert subsystem was also expanded with a module for selecting the effective organization of a neural network and the Decision-maker module was automated.

The system from Fig. 6 works in two basic modes: *Learning mode*, in which the symptom base is created. It contains records binding a specific type of attack with a traffic parameter vector consisting of values indicated by measuring sensors. A decision maker who classifies symptoms in cases where such a decision cannot be taken automatically is involved in creating the symptom database; *Attack detection mode*, when the parameters values determined by the measurement sensors are fed directly to the input of the expert subsystem. Based on the previously defined analysis,

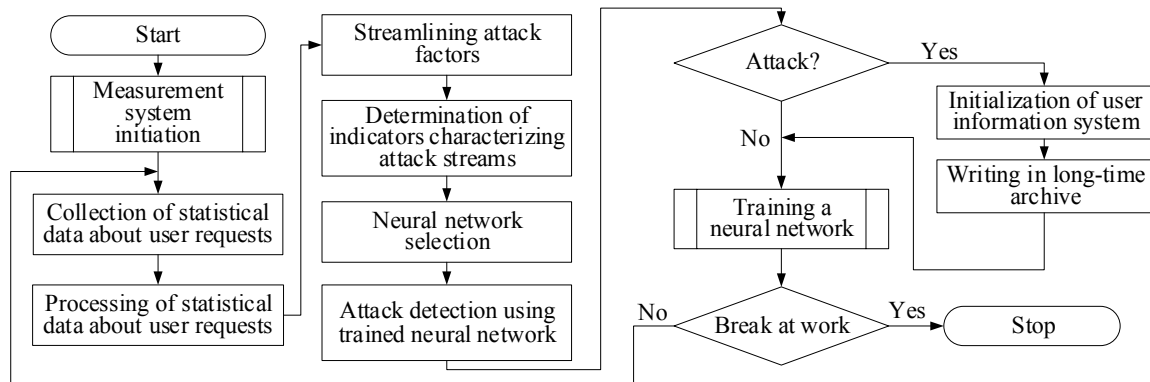


Fig. 7. Generalized algorithm of the MIS attack detection system with artificial neural networks

order to determine and remove its source. If the data from the set M do not match the reference data M_w , a false device message is automatically generated that appeared in the ether.

The key task, solved during the system design, is to create an effective classification model. Such a model is extremely difficult to define in one empirical or analytical step. Therefore, we use a group of alternative methods for this purpose based on various thematically distant areas of computer science. The following methods were used for this purpose: the support vector machine, k -nearest neighbors, neural networks, and the decision tree method. These methods have been discussed, among others in [12, 13, 14, 15, 16].

In order to detect an attack on a protected set of servers as quickly as possible, the system presented in Fig. 5 was equipped with the functioning anomaly detection system described in [6]. If the detection of anomalies of action is performed using neural networks, the generalized operation algorithm, assuming that the neural network has been previously learned, has the form shown in Fig. 7.

Data concerning web application usage are collected using a set of software and hardware sensors, which are part of the intrusion detection system. Time, location, and operational data are collected for each request. After proper preparation they are processed statistically. Then, using the path creation algorithm, streams of attack factors are formed relative to the logical and load type of the page. The set of indicators used to describe the state of the web application depends on the time and day of the week.

Initially, the training procedure is based on simulated attacks, then it is part of the functioning of the information system. This procedure is presented in Fig. 8. As an input, the algorithm uses: B_{pr} – the threshold value of the total square error and N – the number of learning cycles. At the inputs of the neural network, the values of symptoms of the i -th pattern are given, and then sends signals to subsequent layers of the network. The output signals of the neural network are interpreted, for each of them the error value is determined, characterizing the difference between the issued signal and the value specified by the pattern. Zero error means that the answer matches. Otherwise, correction factors are introduced for the synaptic weight of connections. Then the above actions are repeated for the next pattern. The analysis of all patterns is treated as one cycle of network learning. At the end of the cycle, the B error square value is compared to the B_{pr} threshold error value. The algorithm ends when it reaches the specified number of iterations or when the error is less than the threshold.

5. Research experiment and summary

The IBM SPSS Modeler and OriginPro environments as well as the software and hardware prototype of the designed device were used to conduct the research experiment. It consisted of two steps. The first carried out the procedure of filling the symptom base with attack patterns. During the process, normalization of numeric parameter values

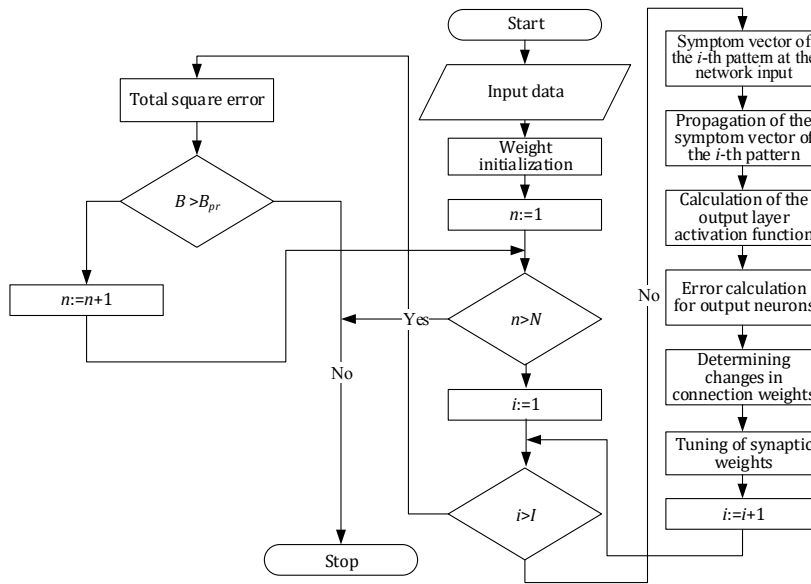


Fig. 8. Neural network learning algorithm

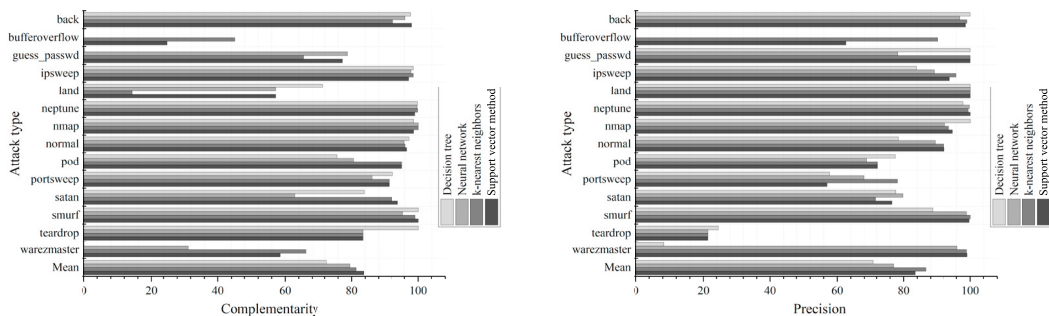


Fig. 9. Comparison of SWA effectiveness for various detection methods and types of attacks: a. Completeness, b. Precision

and conversion to binary values of text parameters, as well as classification of database records, was performed. In the second step, using the software test sequence generator imitating the output of the measurement sensors, the accuracy and completeness of attack detection was determined. The results of the experiment for various types of attacks are shown in Fig. 9. The effectiveness of 4 different detection methods has been examined 14 different DDoS attacks for two key parameters: completeness and precision of detection. In order to determine the generalized effectiveness of methods, the drawings also present the average effectiveness of individual methods for all attacks. Fig. 10 for each of the four detection methods presents the basic parameters averaged for 14 types of attacks: classification correctness, precision; completeness and record.

Previous work has demonstrated the effectiveness of the methods used to detect MIS threats, especially in the field of DDoS attacks. At relatively low costs, you can achieve system efficiency compared to many times more expensive commercial solutions. In addition, detection can be carried out at any of the MIS levels, including the level of intelligent measuring sensors.

Currently testing of the designed solution in real conditions is underway. To this end, motion analysis sensors based on the Raspberry PI platform have been introduced into a secure computing and communication environment. They have been deployed wherever it is possible to launch a DDoS attack. The test system will be loaded with traffic and

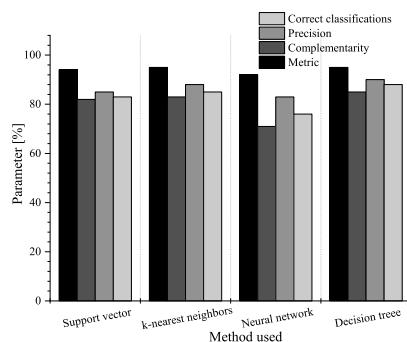


Fig. 10. Average parameter values of compared algorithms

computational tasks from the test event generator, configured so that tasks and loads are similar to those found in MIS. Thanks to this, the analyzed event will have a stochastic character - as close as possible to the real one. As before, the selected most common attack types and the extended range of detection methods will be analyzed. The results of the above studies will be presented in subsequent publications of the authors.

Further work will focus on expanding the range of analyzed protocols and replacing traditional computing servers with Raspberry Pi motion sensor resources. To this end, the sensors will be connected using a multi-channel, multiple-bent reconfigurable optical bus. The reconfiguration of the bus connection system will be managed by a program extensively using machine learning.

References

- [1] Greengard, S. "The new face of war". *Communications of the ACM*, v. 53, n. 12, p. 20-22, 2010.
- [2] Elayat, Y. et al. "Zero Days VR". *Proceeding SIGGRAPH '17 ACM SIGGRAPH 2017 Computer Animation Festival*. Los Angeles: [s.n.]. 2017. p. 37-37.
- [3] Feldman, C. G. "The Practical Guide to Business Process Reengineering Using IDEF0". London: Dorset House, 1998.
- [4] Marca, D. A.; McGowan, C. L. "IDEF0 and SADT". *A Modeler's Guide*. Auburndale: OpenProcess, Inc., 2006.
- [5] Paja, W. "Feature Selection Methods Based on Decision Rule and Tree Models". In: Czarnowski, I.; Howlett, R. J.; Jain, L. C. *Intelligent Decision Technologies 2016: Proceedings of the 8th KES International Conference on Intelligent Decision Technologies (KES-IDT 2016) - Part II*. Cham: Springer International Publishing, 2016. p. 63-70.
- [6] Hajder, M.; Hajder, P.; Nycz, M. "Inteligentna analiza danych jako metoda detekcji ataków na sieci". In: Hajder, M. *Innowacyjna gmina. Bezpieczeństwo i ekologia*. Rzeszów: Wydawnictwo Wyższej Szkoły Informatyki i Zarządzania z siedzibą w Rzeszowie, 2013. Cap. 3, p. 31-56.
- [7] Cudek, P.; Paja, W.; Wrzesien, M. "Automatic System for Classification of Melanocytic Skin Lesions Based on Images Recognition". In: Czachórski, T.; Kozielski, S.; Stanczyk, U. *Man-Machine Interactions 2, Advances in Intelligent and Soft Computing*. [S.l.]: Springer-Verlag Berlin Heidelberg, 2011. p. 189-196.
- [8] Paja, W. "Medical diagnosis support and accuracy improvement by application of total scoring from feature selection approach". 2015 Federated Conference on Computer Science and Information Systems (FedCSIS). Lodz: [s.n.]. 2015. p. 281-286.
- [9] Geier, J. "Designing and Deploying 802.11n Wireless Networks". Indianapolis: Cisco Press, 2010.
- [10] Yuce, M.; Jamil, K. "Wireless Body Area Networks: Technology, Implementation, and Applications". Singapore: Pan Stanford Publishing, 2011.
- [11] Ganesh, R.; Pahlavan, K. "Wireless Network Deployments". Chichester: Springer, 2010.
- [12] Collins, M. "Network Security Through Data Analysis". Building Situational Awareness. Sebastopol: O'Reilly, 2013.
- [13] Fouss, F.; Saerens, M.; Shimbo, M. "Algorithms and Models for Network Data and Link Analysis". New York: Cambridge University Press, 2013.
- [14] Choudhary, A. K.; Swarup, A. "Neural network approach for intrusion detection". *Proceedings of the 2nd International Conference on Interaction Sciences: Information Technology, Culture and Human*. Seoul: [s.n.]. 2009. p. 1297-1301.
- [15] Amigoni, F. et al. "Integrating Partial Models of Network Normality via Cooperative Negotiation: An Approach to Development of Multiagent Intrusion Detection Systems". *Proceedings of the 2008 IEEE/WIC/ACM International Conference on Web Intelligence and Intelligent Agent Technology*. Washington: [s.n.]. 2008. p. 531-537.
- [16] Abuhelaleh, M. A.; Elleithy, K. M. "Security in wireless sensor networks: key intrusion detection module in SOOAWSN". *Proceedings of the 14th Communications and Networking Symposium*. Boston: [s.n.]. 2011. p. 56-61.